

Capability sheet — what the system actually does

Tea estate management for the Sylhet gardens. Every claim below was read off the source code, not the documentation. **If a taka moves, there is a row for it.**

1 — CORE FUNCTIONS

Workforce	Worker records, zones, fields and supervisor assignment.
Attendance	Daily register — present / late / absent / leave. Late pays a full day.
Leaf collection	Supervisor weighs each worker's kilos, per day, in the field.
Payroll & Wage	Wage computed, four deductions applied, payslip issued: draft → review → approved → paid.
Loans & Advances	Issued by an administrator, recovered from daily earnings, closed automatically.
Finance	A single ledger. Revenue, expense, payroll and loan movement, all traceable.
Reports	Labour-cost visibility and a formatted PDF export.
bKash Payout	Wages sent to the worker's mobile wallet. Simulated — no bKash API is called.

2 — WHAT MAKES IT DIFFERENT

Daily settlement	The estate settles every day , not at month end. Debt moves daily; the payslip is a <i>statement</i> , not the payment. Deductions are recorded , never forecast.
One money path	Approving a withdrawal does not pay it. Exactly one action moves cash, so the same taka cannot be spent twice.
Payout slip	The slip chooses who is paid, never how much . Rows match on estate ID <i>and</i> mobile number; the amount comes from the database. An edited file can stop a payment — it cannot cause a wrong one.
Offline-first PWA	Supervisors work with no signal. Entries queue on the device and replay on reconnection, each carrying a unique key so a retry cannot duplicate a day's work.
Bangla for workers	The entire worker console is in Bangla — wages, deductions, loan balance, notifications.
Live, not polled	Admin, supervisor and worker screens update over WebSocket without refreshing.
Audited	Every state change writes an audit row. Ledger postings are idempotent and can never be negative.

3 — AI FEATURES (12 endpoints, plus 2 statistical calibrations)

Vision	Leaf grade suggestion · leaf health / disease detection.
Advisory	Pluck-round advisor · weather briefing · loan risk score · field case review.
Language	Cha Bot (ask in plain Bangla or English) · SMS rewrite · loan note · report writer · worker-data extraction.
No model at all	Proxy-attendance anomaly flags and the rain-impact factor are statistics computed from the estate's own records — not a model. We call them data-driven calibration, because that is what they are.

Two rules we hold to

- 1. It advises, it never decides.** No model output is ever written automatically to a grade, a wage or a status. Grade A carries a Tk 1/kg bonus, so the photo grader *suggests* and the field stays empty until a person chooses.
- 2. We report the measurement, not the hope.** Leaf grading scored **56.7% on 97 labelled Sylhet photographs against a 51% always-guess baseline ($p = 0.15$)** — statistically indistinguishable from guessing, and we say so. The leaf health detector has never been measured, and we claim no accuracy for it.

4 — SECURITY: IDENTITY AND ACCESS

Passwords	BCrypt hashes. Never stored, logged or transmitted in plain text.
Worker login	Mobile number + unique 4-digit PIN, hashed. The number identifies, the PIN proves — four digits alone identify nobody.
Tokens	JWT signed with HS384 , 24-hour expiry. The application refuses to start if the secret is too short for the algorithm, so a weak key cannot reach production unnoticed.
Roles	Three levels — ADMIN, SUPERVISOR, WORKER — enforced per endpoint, not in the UI.
Registration	Public signup cannot self-grant administrator. Accounts wait in an approval queue.
AI database access	The language model never touches a base table. It uses a read-only database role against five curated views , behind a SQL keyword guard with an injected row limit.

5 — SECURITY: FLOODING, ABUSE AND DENIAL OF SERVICE

General API limit	300 requests / 60s per client IP on every <code>/api/v1/*</code> route.
Login limit	5 attempts / 60s per client IP on the login routes — a separate filter, so a genuine login block does not also consume the general budget.
Correct refusal	HTTP 429 Too Many Requests with a <code>Retry-After</code> header, so a well-behaved client knows when to come back.
The limiter cannot be turned into the attack	Both filters evict stale buckets at a threshold. Without that, an attacker cycling forged source addresses would grow the map until the JVM ran out of memory.
IP spoofing closed	X-Forwarded-For is honoured only from proxies on an explicit trust list, which is empty by default — so only the real socket address counts.

A real vulnerability we found and fixed

The rate limiter originally read X-Forwarded-For unconditionally. Anyone could send a made-up value on every request, land in a fresh bucket each time, and get **unlimited login attempts**. The limiter existed and was trivially bypassable — which is worse than none, because it looked like protection. Only listed proxies are trusted now.

6 — SECURITY: INTERCEPTION AND MAN-IN-THE-MIDDLE

HSTS	max-age one year, includeSubDomains. After the first visit the browser refuses plain HTTP outright.
TLS	HTTPS in deployment. Locally, an optional PKCS12 keystore gives encrypted phone-on-LAN demos — the keystore is generated per machine and never committed, because committing one publishes its private key.
Referrer-Policy	strict-origin-when-cross-origin — URLs do not leak to third parties.
Clickjacking	X-Frame-Options: DENY. The console cannot be framed by another site.
CORS allowlist	Enforced on both the REST API and the WebSocket handshake, and it holds <code>http</code> <i>and</i> <code>https</code> entries so enabling TLS does not silently break every request.
No session to steal	Sessions are stateless . There is no session cookie to hijack or fixate.

7 — WHAT WE DO NOT CLAIM

CSRF is off, deliberately	The API is stateless and authenticates from an Authorization header, not a cookie. A cross-site request cannot attach that header, so there is nothing to forge. Leaving CSRF on <i>with</i> cookies would be the mistake.
Rate limits are per instance	They are in-memory, so they stop a single abusive client — not a distributed denial of service. Real DDoS is absorbed upstream at the network layer, not in application code. We do not pretend otherwise.
No CSP yet	A starter policy exists but is opt-in: a strict policy breaks the Leaflet map tiles and the camera used for leaf photographs. A documented trade-off, not an oversight.
Leaf health is unmeasured	It is the largest untested claim in the project and is listed as the current top priority.

Stack — Spring Boot (Java) REST API on PostgreSQL with 42 Flyway migrations · React + Vite + Tailwind progressive web app · FastAPI AI service · Docker. 33 entities, 24 controllers, 24 page components.